SECURITY ASSESSMENT REPORT

Target: https://vulnerable-app.local (simulated)

Date: 2026-11-13

Assessor: Saad (Portfolio Project)

Executive Summary

This assessment identified **7 vulnerabilities** in the target application: **3 CRITICAL** and **4 HIGH**. Immediate remediation is required for the CRITICAL findings to prevent full system compromise.

Findings Summary

ID	Vulnerability	CVSS	Severity	OWASP
VULN-001	SQL Injection (Login)	9.8	CRITICAL	A03:2021 – Injection
VULN-002	Reflected XSS (Search)	6.1	HIGH	A03:2021 – Injection
VULN-003	SSRF (Image Fetch)	8.6	HIGH	A10:2021 – SSRF
VULN-004	XXE (XML Upload)	9.1	CRITICAL	A05:2021 – Security
VULN-005	IDOR (User Profile)	8.1	HIGH	A01:2021 – Broken Ac
VULN-006	Broken Authentication (Weak JWT)	9.1	CRITICAL	A07:2021 – Identific
VULN-007	Security Misconfiguration (Debug)	7.5	HIGH	A05:2021 – Security

Vulnerability Details

VULN-001 — SQL Injection (Login)

CVSS: 9.8 (CRITICAL)

OWASP: A03:2021 – Injection

CWE: CWE-89

Evidence: POST /login username=admin' OR '1'='1 → 200 OK + user data

Impact: Full database compromise (user credentials, PII)

Remediation: Use parameterized queries (PDO/MySQLi)

VULN-002 — Reflected XSS (Search)

CVSS: 6.1 (HIGH)

OWASP: A03:2021 – Injection

CWE: CWE-79

Evidence: GET /search?q=alert(1) → reflected in HTML

Impact: Session hijacking, phishing, defacement

Remediation: Output encoding (htmlspecialchars), CSP header

VULN-003 — SSRF (Image Fetch)

CVSS: 8.6 (HIGH)

OWASP: A10:2021 – SSRF

CWE: CWE-918

Evidence: GET /fetch?url=http://169.254.169.254/ → AWS metadata returned

Impact: Cloud credential theft, internal network scan

Remediation: Whitelist URLs, block private IP ranges

VULN-004 — XXE (XML Upload)

CVSS: 9.1 (CRITICAL)

OWASP: A05:2021 – Security Misconfiguration

CWE: CWE-611

Evidence: POST /upload XML with → file content

Impact: File disclosure, SSRF, RCE potential

Remediation: Disable external entities (defusedxml)

VULN-005 — IDOR (User Profile)

CVSS: 8.1 (HIGH)

OWASP: A01:2021 – Broken Access Control

CWE: CWE-639

Evidence: GET /api/users/2 with user1's token → user2's data

Impact: Horizontal privilege escalation (all users' data)

Remediation: Enforce ownership check (user_id == token.sub)

VULN-006 — Broken Authentication (Weak JWT)

CVSS: 9.1 (CRITICAL)

OWASP: A07:2021 – Identification and Authentication Failures

CWE: CWE-798

Evidence: JWT secret 'secret123' cracked in <1s (hashcat)

Impact: Full account takeover (forge any token)

Remediation: Strong random secret (32+ bytes), rotate regularly

VULN-007 — Security Misconfiguration (Debug)

CVSS: 7.5 (HIGH)

OWASP: A05:2021 – Security Misconfiguration

CWE: CWE-489

Evidence: GET /debug → Werkzeug debugger with interactive shell

Impact: RCE via debugger (PIN bypass)

Remediation: Disable debug=True in production

Remediation Plan

Immediate

• SQL Injection (VULN-001): parameterized queries (PDO/MySQLi)

• Weak JWT (VULN-006): rotate secret, 32+ random bytes

• Reflected XSS (VULN-002): output encoding + CSP

Short Term

• XXE (VULN-004): disable external entities (defusedxml)

• SSRF (VULN-003): URL whitelist + block 169.254.169.254

• IDOR (VULN-005): ownership check (user_id == token.sub)

• Debug (VULN-007): set debug=False in production

Long Term

• Implement WAF (ModSecurity / Cloudflare)

• Security awareness training for all developers

• Quarterly penetration testing

Business Impact

Financial: $500,000 (average data breach cost)

Reputation: High (customer trust loss)

Legal: GDPR fines (up to 4% annual revenue)

Operational: 2 weeks downtime